

Identity & Access Governance + Risk Mapping

Final Project Report

Active Directory • Group Policy • Least Privilege • Security Auditing



Portfolio Lab Environment

Windows Server 2022 | Windows 11 Enterprise | vanglab.test

Prepared August 2026

Executive Summary

This portfolio project implements and validates a small Active Directory identity and access governance environment. The lab centralizes authentication, uses AGDLP security groups for department access, applies domain and workstation security through Group Policy, records identity-management changes through Windows Security auditing, and tests access from a domain-joined Windows 11 workstation.

Hands-on validation included positive and negative department-access tests, a five-attempt account lockout and administrative recovery, a five-minute workstation inactivity lock, Security log review for group and account changes, and a complete employee lifecycle scenario covering onboarding, department transfer, and offboarding. Framework mappings show practical alignment to NIST CSF 2.0 and CIS Controls v8.1; they are not presented as a formal compliance assessment.

1. Project Overview

This project built and validated a small business identity and access management environment using Microsoft Active Directory. The lab demonstrates how centralized authentication, structured user and computer organization, security groups, least-privilege permissions, Group Policy, security auditing, and identity lifecycle processes can be combined to manage employee access to departmental resources.

A Windows Server 2022 domain controller (DC01) hosts the vanglab.test domain, DNS, Active Directory, centralized CompanyShare, domain account-security policy, and identity-management audit logs. A Windows 11 Enterprise workstation (CLIENT01) was joined to the domain and used to validate employee sign-in, role-based file access, and workstation Group Policy enforcement. Department access remained group-based through the AGDLP model rather than direct user permissions.

The completed environment demonstrates role-based access control, least privilege, account lifecycle management, centralized administration, Group Policy enforcement, administrative audit trails, positive/negative access validation, and evidence-based control review.

Project objectives

- Create a functional Active Directory domain and organized OU structure.
- Create employee, group, workstation, service-account, and disabled-account structures.
- Implement department-based access using Global and Domain Local security groups.
- Protect shared departmental folders with share and NTFS permissions.
- Join a separate Windows 11 workstation to the domain and validate authentication.
- Prove authorized access works while unrelated departmental access is denied.
- Map the implemented controls to common identity-governance and security practices.
- Produce screenshots, testing evidence, risk mapping, and an architecture diagram for portfolio use.
- Configure and validate domain password, account-lockout, and workstation inactivity policies through Group Policy.
- Enable Active Directory security auditing and review Security log events for group and account changes.
- Simulate a complete identity lifecycle: onboarding, department transfer, access revocation, and offboarding.

Final lab environment

Component	Configuration	Purpose
DC01	Windows Server 2022; 192.168.50.10	Domain Controller, AD DS, DNS, CompanyShare
CLIENT01	Windows 11 Enterprise; 192.168.50.20	Domain-joined employee workstation for testing
Domain	vanglab.test	Centralized authentication and directory services
Private network	VangLabNet	Internal communication between DC01 and CLIENT01
Shared resource	\\DC01\CompanyShare	Centralized departmental file access

Component	Configuration	Purpose
Domain account security	VangLab Domain Account Security GPO	Password policy and five-attempt account lockout
Workstation security	VangLab Workstation Security GPO	Five-minute automatic session lock on CLIENT01
AD auditing	VangLab Domain Controller Auditing GPO	Security Group Management and User Account Management events

2. Identity and Access Design

The Active Directory structure separates administrative object types and employee departments so that accounts and permissions can be managed consistently. Users are placed into department-based Global groups, which are then nested into resource-specific Domain Local groups. Permissions are assigned to the Domain Local groups, not directly to users.

Group-based access model

- GG_All_Employees represents active employees who require access to common company resources.
- Department Global groups represent employee roles: GG_Finance, GG_HR, GG_IT, GG_Sales, and GG_Management.
- Domain Local groups represent resource permissions: DL_Finance_Modify, DL_HR_Modify, DL_IT_Modify, DL_Sales_Modify, and DL_Management_Modify.
- The relationship follows AGDLP: Accounts → Global groups → Domain Local groups → Permissions.
- Disabled/former employee accounts are separated from active users and excluded from active employee access groups.

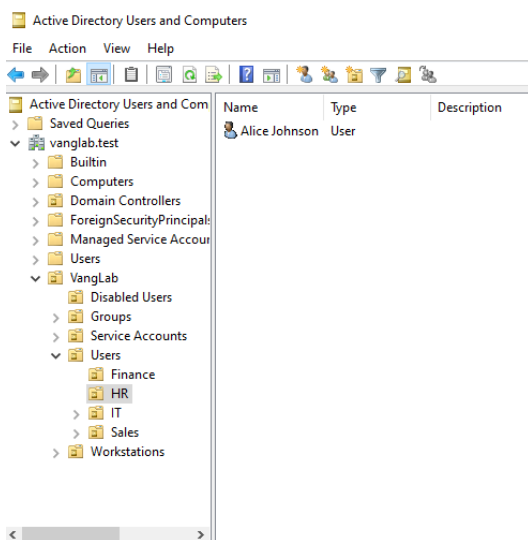


Figure 1. OU structure separating users, groups, workstations, service accounts, and disabled users.

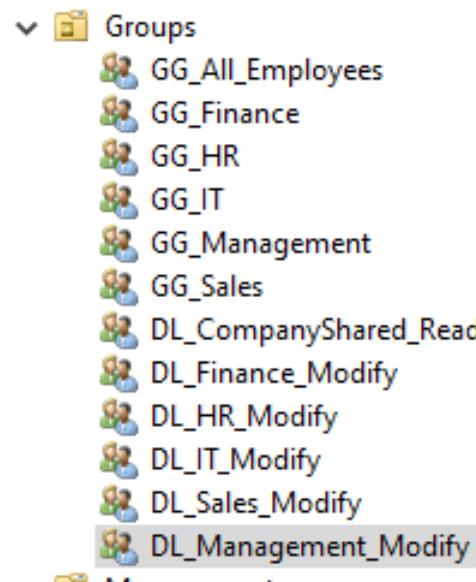


Figure 2. Global and Domain Local security-group structure.

3. Shared Folder and Permission Implementation

A centralized CompanyShare was created on DC01 with department folders for Finance, HR, IT, Sales, and Management. The root share allows active employees to reach the shared location, while NTFS permissions on each department folder enforce separation between departments.

- GG_All_Employees is nested into DL_CompanyShared_Read for common access to the root shared resource.
- Each department Global group is nested into its corresponding Domain Local Modify group.
- Each department Domain Local group receives Modify permission only on its matching folder.
- No direct user-specific folder permissions are required for normal employee access.

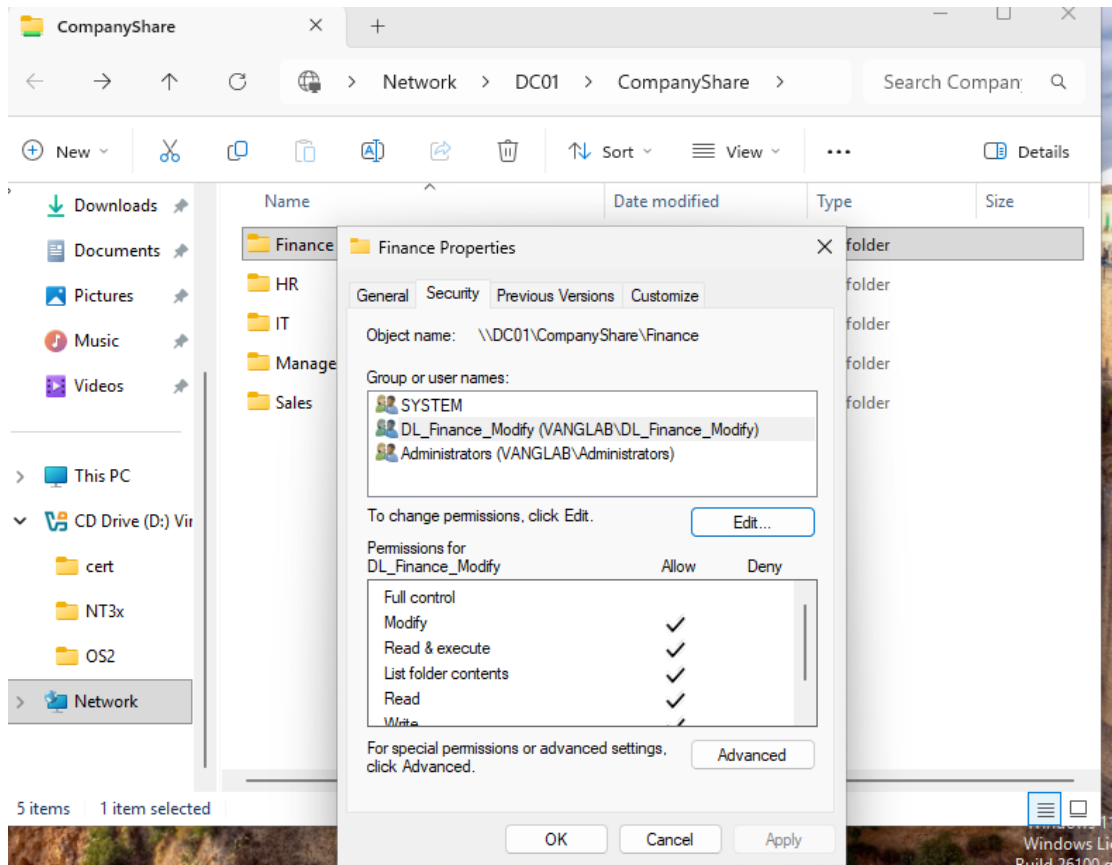


Figure 3. Finance NTFS permissions assigned to DL_Finance_Modify.

4. Domain Client Deployment and Authentication

CLIENT01 was created as a separate Windows 11 Enterprise workstation so the environment could be tested from the perspective of a normal employee. The workstation uses DC01 as its DNS server, successfully discovers the Active Directory domain through DNS, joins vanglab.test, and authenticates domain users.

During setup, CLIENT01 initially used the VirtualBox NAT DNS service, which could reach the internet but could not resolve the private Active Directory domain. Configuring CLIENT01 to use DC01 at 192.168.50.10 resolved domain discovery and allowed the workstation to join the domain successfully.

```
C:\Users\brian.lee>ipconfig/all

Windows IP Configuration

Host Name . . . . . : CLIENT01
Primary Dns Suffix . . . . . : vanglab.test
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : vanglab.test

Ethernet adapter Ethernet 2:

Connection-specific DNS Suffix . : 
Description . . . . . : Intel(R) PRO/1000 MT Desktop Adapter #2
Physical Address. . . . . : 08-00-27-9F-3C-79
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::b311:97d0:a3e:1902K7(Preferred)
IPv4 Address. . . . . : 192.168.50.20(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 
DHCPv6 IAID . . . . . : 168296487
DHCPv6 Client DUID. . . . . : 00-01-00-01-31-F3-16-CB-08-00-27-75-5A-60
DNS Servers . . . . . : 192.168.50.10
NetBIOS over Tcpip. . . . . : Enabled
```

CLIENT01 network and DNS configuration

```
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\brian.lee>whoami
vanglab\brian.lee

C:\Users\brian.lee>
```

Domain user authentication confirmed with whoami

5. Access Validation Results

Access testing was performed from CLIENT01 using representative employees from each department. Each user was expected to create, edit, and delete files in the assigned department folder while being denied access to unrelated department folders.

User	Department	Expected access	Result
Brian Lee	Finance	Finance Modify; unrelated folders denied	PASS
Alice Johnson	HR	HR Modify; unrelated folders denied	PASS
Daniel Kim	IT	IT Modify; unrelated folders denied	PASS
Carla Nguyen	Sales	Sales Modify; unrelated folders denied	PASS
Eva Martinez	Management	Management Modify; unrelated folders denied	PASS

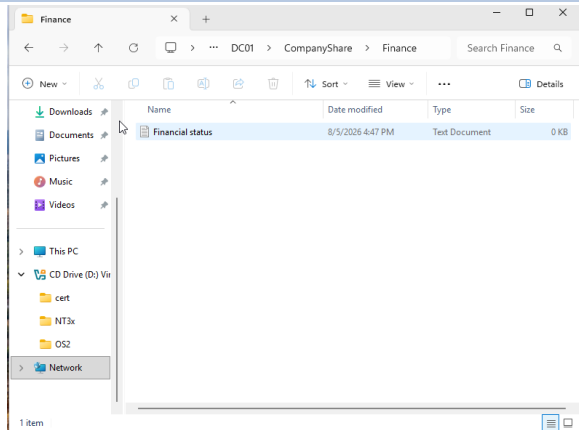


Figure 4. Authorized Finance access confirmed from CLIENT01.

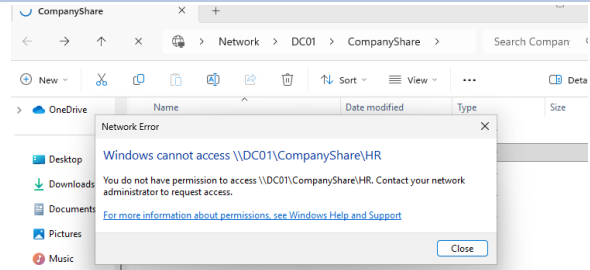


Figure 5. Unauthorized HR access denied for the Finance user.

6. Group Policy and Account Security

Group Policy was added to demonstrate centralized enforcement of security rules beyond folder authorization. A custom domain-level GPO was used for domain account security, while a separate workstation GPO was linked to the Workstations OU so computer-specific controls could be scoped to CLIENT01.

The domain policy was validated with `gpupdate` and `net accounts /domain`. Account lockout was tested end-to-end by intentionally entering an incorrect password five times, confirming the lockout in ADUC, unlocking the account administratively, and verifying a successful sign-in afterward. The workstation policy was verified with `gpresult /scope computer /r` and behaviorally tested by allowing CLIENT01 to remain idle until Windows automatically locked the session.

Control	Configured value	Validation
Minimum password length	12 characters	Effective domain policy verified
Password history	12 passwords remembered	Effective domain policy verified
Password complexity	Enabled	Configured in domain account-security GPO
Maximum password age	Unlimited	Effective domain policy verified
Account lockout threshold	5 failed attempts	Real lockout triggered from CLIENT01
Lockout duration / reset window	30 min / 30 min	Effective domain policy verified
Workstation inactivity limit	300 seconds	CLIENT01 locked automatically

Lab note: the built-in Default Domain Policy conflicted with the custom lab account-policy settings during validation. Its domain link was disabled so the custom VangLab Domain Account Security GPO could be isolated and tested. This is documented as a lab-specific troubleshooting decision, not as a general production recommendation.

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Administrator>net accounts /domain
Force user logoff how long after time expires?: Never
Minimum password age (days): 1
Maximum password age (days): Unlimited
Minimum password length: 12
Length of password history maintained: 12
Lockout threshold: 5
Lockout duration (minutes): 30
Lockout observation window (minutes): 30
Computer role: PRIMARY
The command completed successfully.

C:\Users\Administrator>
```

Figure 6. Effective domain password and lockout settings.

```
Microsoft (R) Windows (R) Operating System Group Policy Result tool v2.0
© Microsoft Corporation. All rights reserved.

Created on 8/15/2026 at 3:04:51 PM

RSOP data for on CLIENT01 : Logging Mode
-----
OS Configuration: Member Workstation
OS Version: 10.0.26200
Site Name: Default-First-Site-Name
Roaming Profile:
Local Profile:
Connected over a slow link?: No

COMPUTER SETTINGS
-----
ON-CLIENT01,OU-Workstations,OU-Users,OU-VangLab,DC-vanglab,DC-test
Last time Group Policy was applied: 8/15/2026 at 2:56:58 PM
Group Policy was applied from: DC01.vanglab.test
Group Policy slow link threshold: 500 kbps
Domain Name: VANGLAB
Domain Type: Windows 2008 or later

Applied Group Policy Objects
-----
VangLab Workstation Security
VangLab Domain Account Security

The following GPOs were not applied because they were filtered out
-----
Default Domain Policy
Filtering: Disabled (Link)

Local Group Policy
Filtering: Not Applied (Empty)

The computer is a part of the following security groups
-----
```

Figure 7. CLIENT01 shows the workstation security GPO applied.

7. Active Directory Auditing

Advanced Audit Policy was enabled on the Domain Controllers OU through the VangLab Domain Controller Auditing GPO. Security Group Management and User Account Management success events were enabled so important identity changes would generate reviewable Security log records on DC01.

The effective audit policy was verified with auditpol before controlled changes were generated. A dedicated GG_Audit_Test global security group allowed membership changes to be tested without granting department-resource access. Event Viewer then confirmed attributable records for membership additions, removals, and account disablement.

Event ID	Activity demonstrated	Validation
4728	Member added to a security-enabled global group	Addition reviewed on DC01
4729	Member removed from a security-enabled global group	Removal reviewed on DC01
4725	User account disabled	Offboarding action recorded on DC01

```

COMPUTER SETTINGS
-----
CN=DC01,OU=Domain Controllers,DC=vanglab,DC=test
Last time Group Policy was applied: 8/19/2026 at 2:25:52 PM
Group Policy was applied from:      DC01.vanglab.test
Group Policy slow link threshold:   500 kbps
Domain Name:                        VANGLAB
Domain Type:                        Windows 2008 or later

Applied Group Policy Objects
-----
Default Domain Controllers Policy
VangLab Domain Controller Auditing
VangLab Domain Account Security

The following GPOs were not applied because they were filtered out
-----
Local Group Policy
    Filtering:  Not Applied (Empty)

The computer is a part of the following security groups
-----
BUILTIN\Administrators
Everyone
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Users
Windows Authorization Access Group
NT AUTHORITY\NETWORK
NT AUTHORITY\Authenticated Users
  
```

Figure 8. DC01 shows the VangLab Domain Controller Auditing GPO applied.

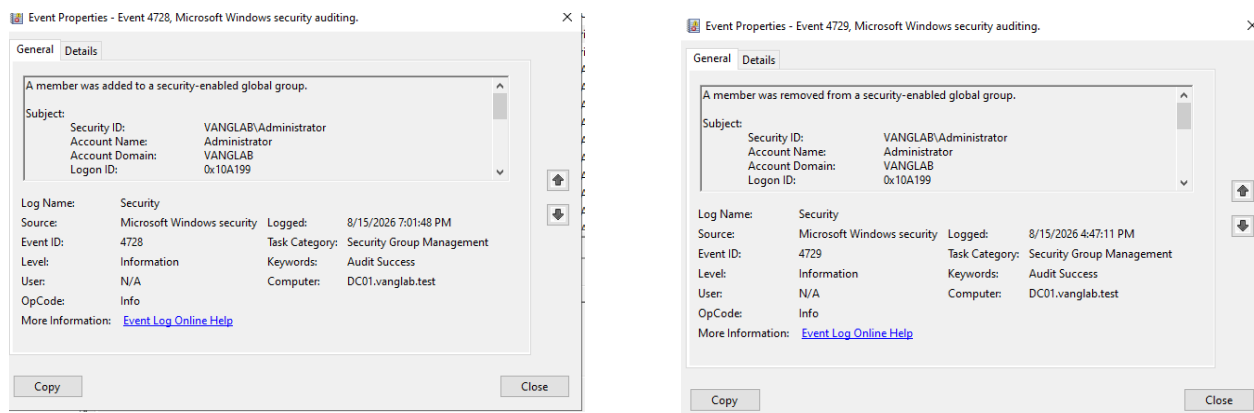


Figure 9. Event 4728 records a security-group membership addition.

Figure 10. Event 4729 records a security-group membership removal.

8. Identity Lifecycle Management

A dedicated test employee, Marcus Reed, was used to demonstrate identity governance across the employee lifecycle without altering the original access-validation users. The scenario covered onboarding into Sales, a transfer from Sales to Finance, and termination/offboarding.

The transfer demonstrated that access followed role-based Global group membership rather than direct user permissions. Marcus was removed from GG_Sales and added to GG_Finance, then fully signed out and back in so Windows created a fresh security token. Finance access became available and Sales access was revoked without changing folder ACLs. During offboarding, the account was disabled and moved to the Disabled Users OU; after a full sign-out, a new domain sign-in was blocked.

Lifecycle stage	Administrative action	Validation result
Onboarding	Create Marcus Reed; add GG_All_Employees and GG_Sales	Domain sign-in succeeded; Sales allowed; unrelated folders denied
Role change	Remove GG_Sales; add GG_Finance; refresh sign-in token	Finance allowed; Sales denied
Offboarding	Disable account and move to Disabled Users OU	Fresh domain sign-in blocked; Event 4725 recorded

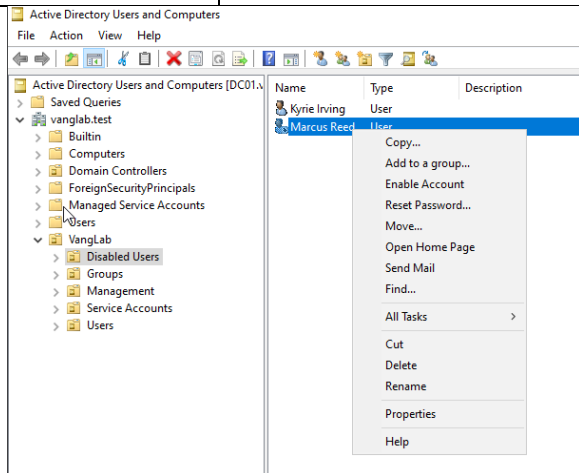


Figure 11. Marcus Reed is separated into the Disabled Users OU.

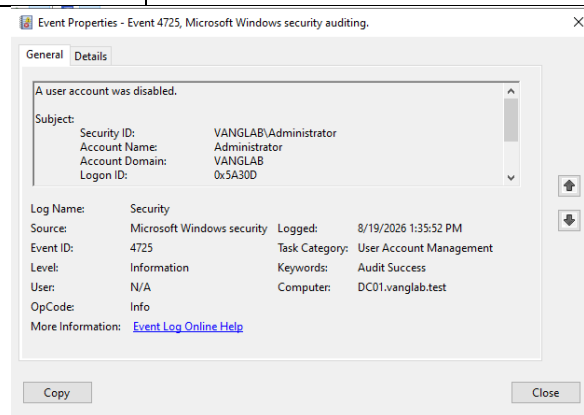


Figure 12. Event 4725 records the account-disable action.

9. Risk and Security Control Mapping

The lab was reviewed as an identity-governance exercise, not only as a technical configuration. The primary risks included excessive access, stale access after role changes, former-user access, direct user permissions, unattended workstations, undetected configuration errors, and insufficient traceability of administrative identity changes.

Risk	Control implemented	Validation / evidence
Excessive or unrelated access	Department security groups and least-privilege folder permissions	Positive and negative folder-access testing
Stale access after role change	Role-based group membership updated during department transfer	Marcus lost Sales access and gained Finance access after token refresh
Former employee retaining access	Account disabled during offboarding and separated from active users	Fresh CLIENT01 sign-in blocked; Event 4725 recorded
Hard-to-manage direct permissions	AGDLP and group-based permission assignment	Access delivered through department groups instead of direct folder ACEs
Password guessing against domain accounts	Domain password policy and five-attempt account lockout	Lockout triggered from CLIENT01 and recovered administratively
Unattended authenticated workstation	Five-minute machine inactivity lock via workstation GPO	CLIENT01 automatically locked after inactivity
Misconfiguration going undetected	Effective-policy verification and end-to-end testing	net accounts, gpresult, auditpol, and user-access tests confirmed behavior
Identity changes lacking traceability	Security Group Management and User Account Management auditing	Events 4728, 4729, and 4725 reviewed in the Security log
Poor directory organization	Structured OUs for users, groups, workstations, service accounts, and disabled users	ADUC screenshots and object placement review

Security principles demonstrated

- Role-based access control (RBAC): access is tied to departmental role.
- Least privilege: users receive only the access required for their assigned department.
- Group-based access management: permissions are administered through security groups.
- Account lifecycle management: inactive accounts are separated from active employees.
- Separation of duties: department data is protected from unrelated departments.
- Centralized administration and auditability: Active Directory, Advanced Audit Policy, and Security log review provide attributable records of identity-management changes.

Framework alignment

The table below maps implemented lab activities to specific NIST Cybersecurity Framework (CSF) 2.0 subcategories and CIS Critical Security Controls v8.1 safeguards. The mappings show practical alignment between the lab and recognized security outcomes; they do not represent a formal compliance assessment or claim that every requirement of a safeguard has been implemented.

Implemented activity	NIST CSF 2.0	CIS Controls v8.1
Centralized Active Directory identities and account management	PR.AA-01	5.6 Centralize Account Management
Domain-user authentication through DC01	PR.AA-03	6.7 Centralize Access Control
AGDLP, departmental RBAC, and least privilege	PR.AA-05	6.7 Centralize Access Control; 6.8 Define and Maintain RBAC
Department NTFS access-control lists	PR.AA-05	3.3 Configure Data Access Control Lists
New-hire onboarding and role-based access granting	PR.AA-01; PR.AA-05	6.1 Establish an Access Granting Process
Department transfer and obsolete-access removal	PR.AA-05	6.2 Establish an Access Revoking Process; 6.8 Define and Maintain Role-Based Access Control
Termination: disable account and revoke active access	PR.AA-01; PR.AA-05	6.2 Establish an Access Revoking Process
Workstation security configuration through Group Policy	PR.PS-01	4.1 Secure Configuration Process; 4.3 Automatic Session Locking
Security audit events generated and reviewed on DC01	PR.PS-04	8.2 Collect Audit Logs; 8.11 Conduct Audit Log Reviews (review activity demonstrated; recurring cadence not implemented)
Architecture and network-system documentation	ID.AM-03	12.4 Establish and Maintain Architecture Diagram(s)

Framework references: NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (February 2024); CIS Critical Security Controls v8.1. Mappings are practical alignments to implemented lab activities, not a claim of full safeguard implementation or a formal compliance assessment.

10. Challenges and Resolutions

Challenge	Resolution
Department OUs were initially created at the wrong level.	Moved the OUs into the correct Users OU after temporarily disabling accidental-deletion protection.
A regular employee account could not sign in locally to DC01.	Recognized this as correct domain-controller security behavior and created CLIENT01 as the employee workstation.
CLIENT01 could not discover vanglab.test while using NAT DNS.	Configured CLIENT01 to use DC01 (192.168.50.10) as DNS, enabling domain discovery and domain join.
Permission correctness needed to be proven rather than assumed.	Performed both authorized and unauthorized access tests for five department users from CLIENT01.
Custom domain account-policy settings conflicted with the built-in Default Domain Policy.	Used effective-policy verification to isolate the conflict, validated the custom VangLab Domain Account Security GPO, and documented the lab-specific link decision.
A disabled employee appeared to remain signed in after offboarding.	Distinguished an existing authenticated session from a fresh domain logon, fully signed the user out, and confirmed the disabled account could no longer authenticate.

11. Architecture Overview

The lab separates CLIENT01 from DC01 while centralizing identity, DNS, Group Policy, security auditing, and file access on the domain controller. CLIENT01 uses DC01 for domain services and reaches departmental resources through the AGDLP-based CompanyShare permission model. The diagram represents the implemented single-domain lab scope.

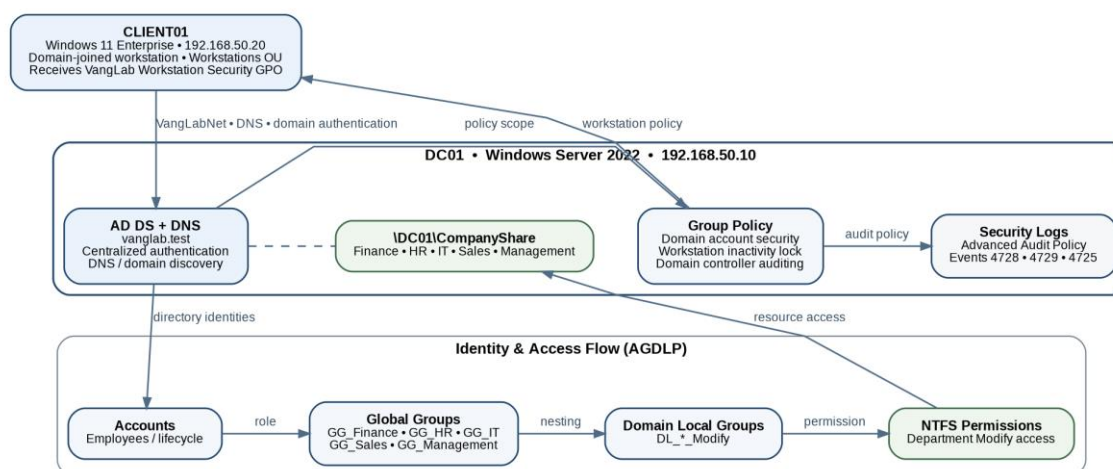


Figure 13. VangLab architecture showing domain services, Group Policy, auditing, AGDLP, and CompanyShare access flow.

12. Skills Demonstrated

- Windows Server 2022 and Active Directory Domain Services administration
- ADUC organization and user, group, computer, and disabled-account management
- DNS configuration, domain discovery, Windows 11 domain join, and domain-user authentication
- AGDLP security-group design, share/NTFS permissions, RBAC, and least privilege
- Group Policy creation, scoping, refresh, and effective-policy verification
- Domain password and account-lockout policy configuration and recovery
- Workstation inactivity-lock policy configuration and validation
- Advanced Audit Policy configuration, auditpol verification, and Event Viewer analysis
- Identity lifecycle administration: onboarding, department transfer, access revocation, and offboarding
- Positive and negative access testing from a domain-joined workstation
- NIST CSF 2.0 / CIS Controls mapping, troubleshooting, evidence collection, and technical documentation

Conclusion

The project successfully implemented and tested a centralized identity and access environment. Department users authenticated through Active Directory, received only the access required for their roles, and were denied unrelated resources. The extended lab also enforced account and workstation security through Group Policy, generated attributable identity-management audit events, and demonstrated onboarding, role transfer, and offboarding. The final design provides practical evidence of IAM administration, access governance, troubleshooting, policy enforcement, audit-log review, risk/control mapping, and professional technical documentation in a reproducible virtual environment.

Appendix A. Evidence Index

Evidence file	What it demonstrates
01-Active-Directory-OU-Structure.png	OU and object organization
02-Security-Group-Structure.png	Global and Domain Local security-group structure
03-All-Employees-Group-Membership.png	Active employee membership in GG_All_Employees
04-Finance-Group-Membership.png	Finance user membership in GG_Finance
05-CLIENT01-Workstations.png	CLIENT01 placed in Workstations OU
06-CLIENT01-Network-DNS-Configuration.png	CLIENT01 IP and DNS configuration
07-Active-Directory-Domain-Discovery.png	LDAP SRV lookup confirming domain discovery
08-Domain-User-Authentication.png	Authenticated domain identity using whoami
09-Unauthorized-Folder-Access-Denied.png	Negative access test
10-Finance-NTFS-Modify-Permissions.png	Finance NTFS Modify permission
11-Brian-Lee-Authorized-Finance-Access.png	Positive Finance access test
Phase8-Effective-Domain-Account-Policy.png	Effective password and account-lockout settings verified on the domain
Phase8-Workstation-GPO-Applied.png	VangLab Workstation Security applied to CLIENT01
Phase9-Domain-Controller-Auditing-GPO-Applied.png	VangLab Domain Controller Auditing applied to DC01
Phase9-Group-Member-Added-Event-4728.png	Audited addition to a security-enabled global group
Phase9-Group-Member-Removed-Event-4729.png	Audited removal from a security-enabled global group
Phase10-Disabled-Former-Employee.png	Disabled employee separated from active users
Phase10-Account-Disabled-Event-4725.png	Audited account disablement during offboarding
VangLab-Architecture-Diagram.png	Overall domain, policy, auditing, AGDLP, and resource-access architecture